THOMSON COURSE TECHNOLOGY

Guide to Network Defense and Countermeasures Third Edition

Chapter 9

Firewalls

Objectives

- Explain what firewalls can and cannot do
- Compare hardware and software firewalls
- Describe common approaches to packet filtering
- Design packet filtering and firewall rule sets

© Cengage Learning 2014

An Overview of Firewalls, Part 1

- Firewall
  - Hardware or software configured to block unauthorized network access
- Firewalls cannot protect against malicious insiders
  - Send proprietary information out of the organization or copy confidential information to disk
- Firewalls cannot protect connections that do not go through it
  - Such as remote dial-up connections

© Cengage Learning 2014

An Overview of Firewalls, Part 2

- Any network firewall is a combination of multiple software and hardware components
  - Term firewall perimeter might be more descriptive
- Earliest firewalls were packet filters
  - Single packet-filtering router was placed at perimeter
- Some firewalls are designed for consumers
  - Norton Security Suite Firewall
  - ZoneAlarm

© Cengage Learning 2014

Overview of Firewalls, Part 3

- With personal firewalls:
  - Establishing rules for blocking traffic are done case-by-case
    - Prompts whether traffic should be allowed or not
- Check Point NGX firewall
  - Example of a firewall designed to protect and monitor large-scale networks
- Firewall appliances
  - Self-contained hardware devices added to a network
  - Cisco PIX is an example

© Cengage Learning 2014

Overview of Firewalls, Part 4

- Firewalls are not a standalone solution
  - Cannot protect from internal threats
  - Need strong security policy and employee education
    - Policy should include strict procedures for keeping patches updated and checking for vulnerabilities
- Firewalls must be combined with
  - Antivirus software
  - IDPS
- Defense in depth (DiD): layered defense strategy that includes an IDPS, firewalls, antivirus software, access control and auditing

© Cengage Learning 2014

Comparing Software and Hardware Firewalls

- Core functions of firewalls:
  - Filtering
  - Proxying
  - Logging
- Following slides cover the two main types of firewalls:
  - Software-based firewalls
  - Hardware-based firewalls

© Cengage Learning 2014

Software-Based Firewalls, Part 1

- Software programs can be combined with hardware devices to create a secure checkpoint
  - Require extensive configuration
- Free firewall programs
  - Logging capabilities are not as robust as some commercial products
  - Configuration can be difficult
  - Popular free firewall programs
    - Netfilter
    - ZoneAlarm

© Cengage Learning 2014

Software-Based Firewalls, Part 2

- Commercial Firewall Programs: Personal firewalls
  - Located between the Ethernet adapter driver and the TCP/IP stack
    - Inspect traffic going between the driver and the stack
  - Popular choices
    - CA Internet Security Suite
    - Norton Internet Security
    - ZoneAlarm Internet Security Suite
    - Kaspersky Internet Security
  - Do not offer extensive firewall protection

© Cengage Learning 2014

Software-Based Firewalls, Part 3

- Commercial firewall programs: Enterprise firewalls
  - Include centralized management option
  - Some are capable of installing multiple instances from a centralized location
  - Some examples include
    - Check Point NGX
    - Proventia security products
- Some products offer user authentication, NAT, encryption, and centralized management

© Cengage Learning 2014

Hardware Firewalls, Part 1

- Advantages
  - Do not depend on conventional OSs
  - Generally more scalable than software firewalls
  - Can handle more data with faster throughput
- Disadvantages
  - They do depend on nonconventional OSs
  - Tend to be more expensive than software products

© Cengage Learning 2014

Hardware Firewalls, Part 2

- Hardware firewall examples:
  - Cisco ASA series
  - Fortinet FortiGate series
  - Barracuda NG Firewall

© Cengage Learning 2014

Firewall Advantages and Disadvantages

Type of firewall	Advantages	Disadvantages
Software—freeware	Small file size; ease of installation	Only minimal features are offered; lack of technical support
Software—commercial personal firewalls	Simple to install; economical; autoconfiguration features help novice users yet give advanced users more fine-tuned control	Not as full-featured as enterprise products and not as robust as hardware appliances; usually installed on single computer systems, which reduces security
Software—commercial enterprise firewalls	Usually installed on a dedicated host for maximum security; centralized administration available for large networks; real-time monitoring and other administrative features	Can be difficult to install and configure; tend to be more expensive
Hardware appliances	More scalable than software firewalls; offer faster throughput	Can be expensive and difficult to patch if bugs or security alerts require it

Table 9-1 Firewall advantages and disadvantages

Packet Filtering and Firewall Rule Sets

- Stateless packet filtering
- Stateful packet filtering
- Packet filtering depends on position of components

© Cengage Learning 2014

Stateless Packet Filtering

- Determines whether to allow or block packets based on information in the protocol headers
- Filtering based on common IP header features
  - IP address
  - Ports
  - TCP flags
- Intruders can get around these defenses
- Advantage: Inexpensive
- Disadvantages: Hard to maintain, vulnerable to IP spoofing, and no form of authentication

© Cengage Learning 2014

Stateless Packet-Filtering Rules

Rule	Source IP	Source port	Destination IP	Destination port	Action
1	Any	Any	192.168.120.0	Above 1023	Allow
2	192.168.120.1	Any	Any	Any	Deny
3	Any	Any	192.168.120.1	Any	Deny
4	192.168.120.0	Any	Any	Any	Allow
5	Any	Any	192.168.120.2	25	Allow
6	Any	Any	192.168.120.3	80	Allow
7	Any	Any	Any	Any	Deny

Table 9-2 Stateless packet-filtering rules

Stateful Packet Filtering, Part 1

- Keeps a record of connections a host computer has made with other computers
  - Maintain a file called a **state table** containing record of all current connections
  - Allows incoming packets to pass through only from external hosts already connected

© Cengage Learning 2014

State Table Example

Source IP	Source port	Destination IP	Destination port	Connection state
192.168.120.101	1037	209.233.19.22	80	Established
192.168.120.104	1022	165.66.28.22	80	Established
192.168.120.107	1010	65.66.122.101	25	Established
192.168.120.102	1035	213.136.87.88	20	Established
223.56.78.11	1899	192.168.120.101	80	Established
206.121.55.8	3558	192.168.120.101	80	Established
224.209.122.1	1079	192.168.120.105	80	Established

Table 9-3 State table example

Stateful Packet Filtering, Part 2

- Windows Firewall
  - One of the most user-friendly packet filters
  - Can limit the type of program traffic with more precision
    - Can even specify exceptions
  - Advanced tab allows more complex settings
    - Can create very specific rules to allow or deny packets based on protocols, ports, IP addresses, and other items

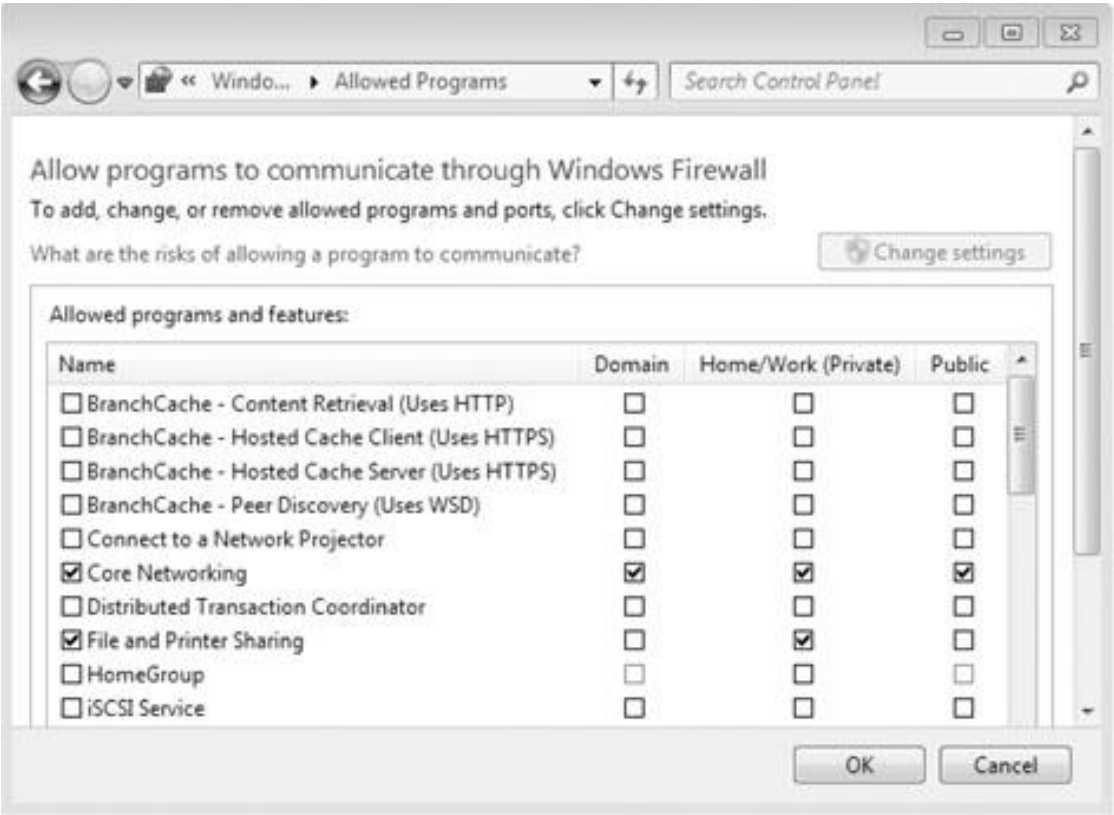
© Cengage Learning 2014

Windows Firewall

Used with permission of Microsoft Corporation

Figure 9-3 Windows Firewall

Programs Allowed in Windows Firewall



Used with permission of Microsoft Corporation

Figure 9-4 Programs allowed in Windows Firewall

Packet Filtering Based on Position, Part 1

- Type of filtering a device can do depends on
  - Position of the device in the firewall perimeter
  - Other hardware or software
- Packet filter placement
  - Between the Internet and a host
    - All inbound and outbound traffic should be accounted for in the packet filter's rule base
  - Between a proxy server and the Internet
    - Proxy server: handles traffic on behalf of computer on the network it protects
    - Rebuilds requests to hide internal IP address information

© Cengage Learning 2014

A Packet Filter Connecting a Proxy Server with the Internet

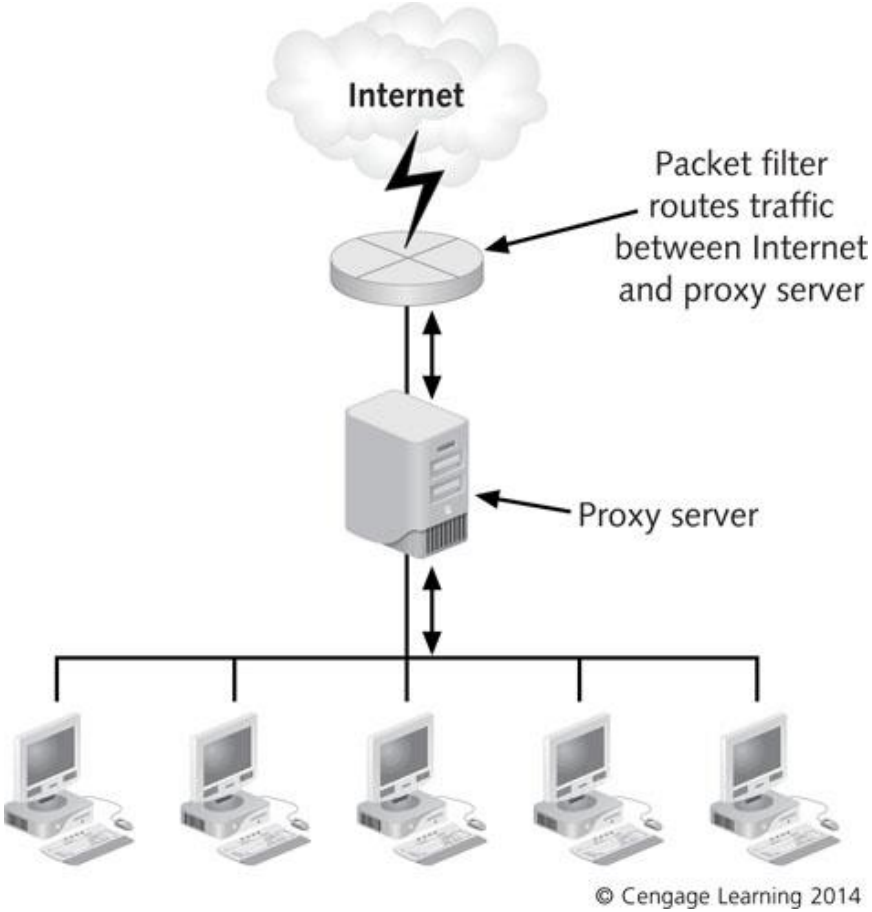


Figure 9-6 A packet filter connecting a proxy server with the Internet

© Cengage Learning 2014

Packet Filtering Based on Position, Part 2

- Packet filter placement (continued)
  - Place packet-filtering devices at either end of the DMZ
    - Filter on DMZ's external interface needs to allow Internet users to gain access to servers on the DMZ but block access to the internal network
    - Filter on DMZ's internal interface enables internal users to access servers on DMZ but not connect to Internet
    - Internal users connect to Internet through a proxy server on DMZ

© Cengage Learning 2014

A Packet Filter Routing Traffic to and from a DMZ

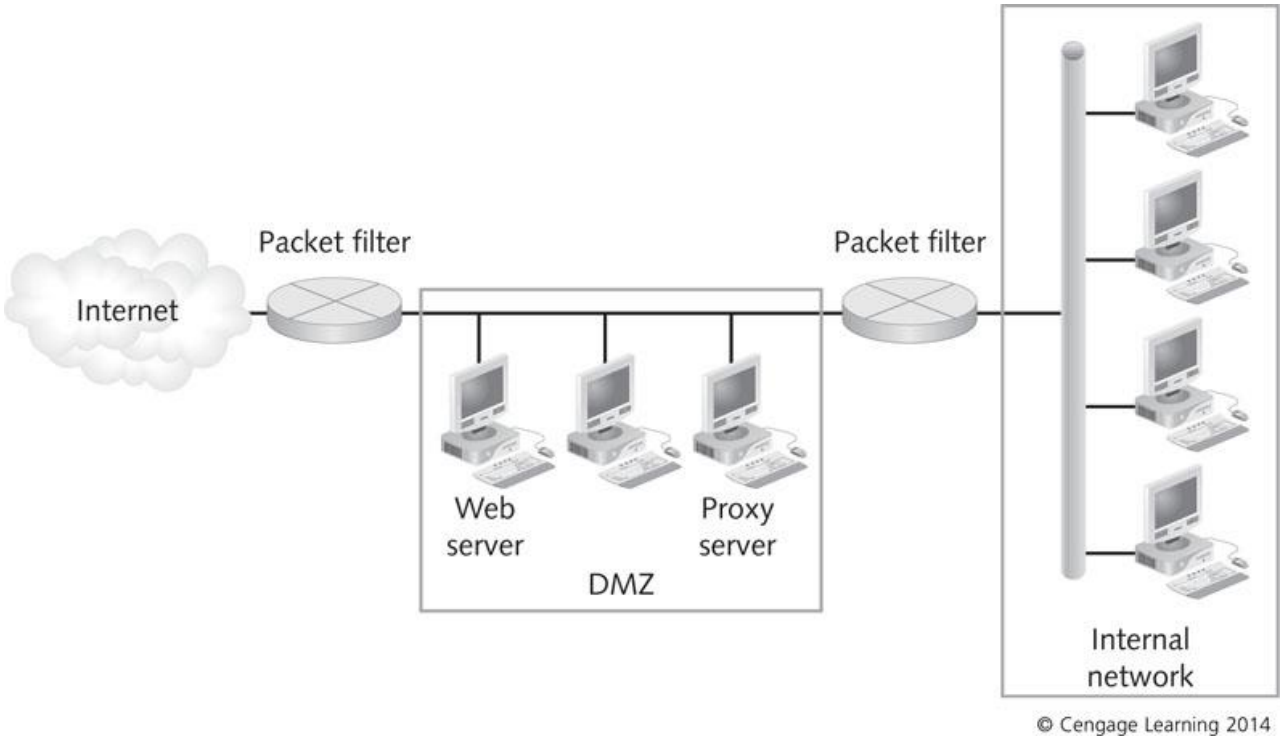


Figure 9-7 A packet filter routing traffic to and from a DMZ

© Cengage Learning 2014

Firewall Rule Sets

- Rule base
  - Tells firewalls what to do when a certain kind of traffic attempts to pass
- Effective firewall rule base should:
  - Be based on organization's security policy
  - Include a firewall policy
  - Be simple and short as possible.
  - Restrict access to ports and subnets on the internal network from the Internet
  - Control Internet services

© Cengage Learning 2014

Base the Rule Base on Your Security Policy, Part 1

- When configuring rules pay attention to
  - Logging and auditing
  - Tracking
  - Filtering
  - Network Address Translation (NAT)
  - Quality of Service (QoS)
  - Desktop security policy
- Rule base is a practical implementation of the organization's policy

© Cengage Learning 2014

Base the Rule Base on Your Security Policy, Part 2

- Common guidelines that need to be reflected in the rule base:
  - Employees have access to Internet with restrictions
  - Public can access company's Web and e-mail server
  - Only authenticated traffic can access the internal LAN
  - Employees are not allowed to use instant-messaging or social networking outside the internal network
  - Traffic from the company's ISP should be allowed
  - Block external traffic by instant-messaging software
  - Only network administrator should be able to access internal network directly from the Internet

© Cengage Learning 2014

Create a Firewall Policy For Application Traffic, Part 1

- **Firewall policy:** addition to security policy that describes how firewalls should handle application traffic
- Risk assessment provides a list of applications
  - And associated threats and vulnerabilities
- General steps to create a firewall policy
  - Identify network applications that are needed
  - Determine methods for securing application traffic
    - Must balance security, user requirements, and cost
  - Consider all firewalls in your network
    - Develop a traffic matrix for each location

© Cengage Learning 2014

Application Traffic Matrix

Application or service	Internal host type	Location	Host security policy	Firewall internal security policy	Firewall external security policy
FTP	Windows	Any	Client only; antivirus	Allow	Deny
FTP	UNIX	Any	Secure Shell (SSH); user ID/password; no anonymous traffic	Allow	Application proxy with user authentication
Telnet	Windows	Any	Client only	Allow	Application proxy with user authentication
Telnet	UNIX	Any	SSH	Allow	Application proxy with user authentication
SMB over IP	Windows	Any	Limit access to shares	Allow local domain only; deny all others	Deny

Table 9-4 Application traffic matrix

Create a Firewall Policy For Application Traffic, Part 2

- Firewalls enable you to control access to your computer or network
  - By controlling access to particular applications
- Options for defining rules
  - Allow traffic
  - Block traffic
  - Ask or prompt – user is prompted when application attempts to access the Internet

© Cengage Learning 2014

Keep the Rule Base Simple

- Keep list of rules as short as possible
  - About 30 rules (no more than 50 rules)
  - Shorter the rule base, faster the firewall will perform
- Firewalls process rules in a particular order
  - Usually rules are numbered sequentially and displayed in a grid
  - Most important rules should be at the top of the list
  - Make the last rule a cleanup rule
    - Handles any other packets that have not been covered in preceding rules

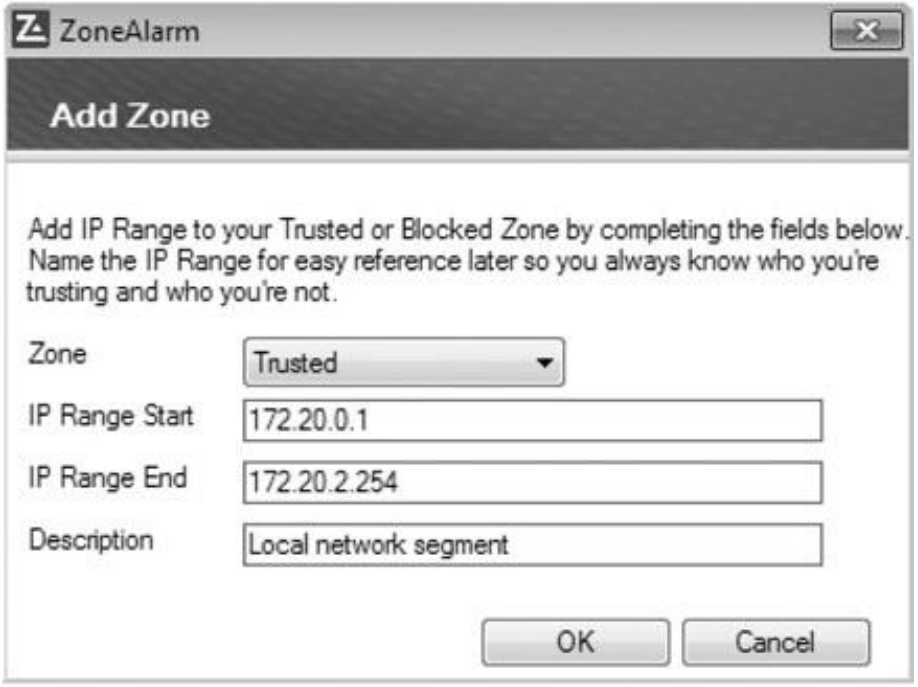
© Cengage Learning 2014

Restrict Subnets, Ports, and Protocols, Part 1

- Filtering by IP addresses
  - You can identify traffic by IP address range
  - Most firewalls start blocking all traffic
    - You need to identify “trusted” networks
    - Firewall should allow traffic from trusted sources

© Cengage Learning 2014

Identifying Trusted Subnets of IP Addresses



Source: ZoneAlarm

Figure 9-8 Identifying trusted subnets or IP addresses

Restrict Subnets, Ports, and Protocols, Part 2

- Filtering by ports
  - TCP and UDP break information into sections called **segments**(TCP) or **datagrams** (UDP)
  - Filters traffic based on TCP or UDP port numbers
    - Commonly called port filtering or protocol filtering
  - Can filter a wide variety of information
  - You can filter out everything but
    - TCP port 80 for Web traffic
    - TCP port 25 for e-mail traffic
    - TCP port 21 for FTP transmissions
  - Combination of an IP address and port number is called a **socket**

© Cengage Learning 2014

Port Numbers Directing Packets

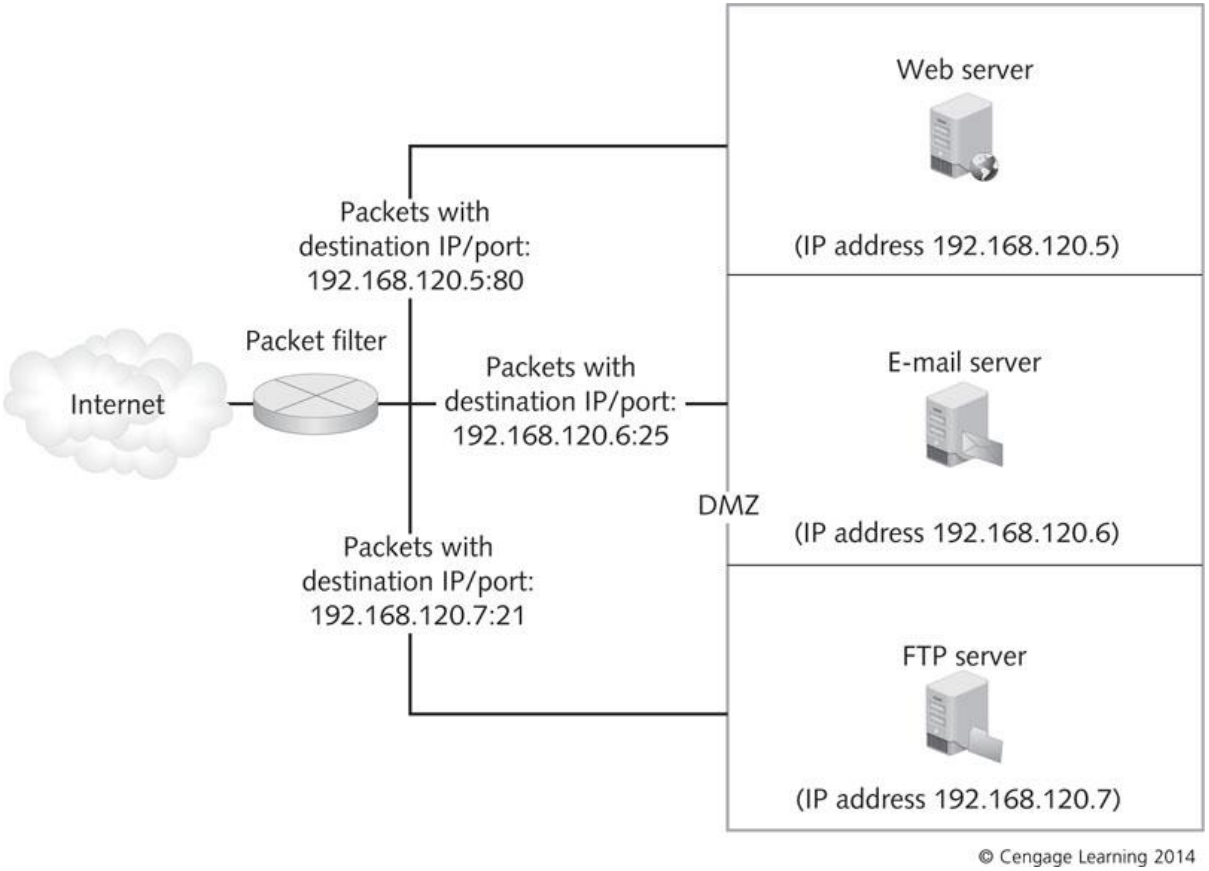


Figure 9-9 Port numbers direct packets to the client or server that needs them

Filtering Windows Services and Ports

Rule	Protocol	Source IP	Source port	Destination IP	Destination port	Action	Service
1	TCP	Any	Any	Any	135	Deny	NetBIOS RPC
2	UDP	Any	Any	Any	135	Deny	NetBIOS RPC
3	TCP	Any	Any	Any	137	Deny	NetBIOS Name Service
4	UDP	Any	Any	Any	137	Deny	NetBIOS Name Resolution
5	UDP	Any	Any	Any	138	Deny	NetBIOS Datagram Service
6	TCP	Any	Any	Any	139	Deny	NetBIOS Session Service
7	UDP	Any	Any	Any	161	Deny	SNMP
8	TCP	Any	Any	Any	445	Deny	SMB/file sharing
9	UDP	Any	Any	Any	1755	Deny	Windows Media
10	TCP	Any	Any	Any	3389	Deny	Remote Desktop Protocol
11	UDP	Any	Any	Any	3389	Deny	Remote Desktop Protocol

Table 9-5 Filtering Windows services and ports

Restrict Subnets, Ports, and Protocols, Part 3

- UNIX has its own set of services that should be blocked when inbound from the Internet

Rule	Protocol	Source IP	Source port	Destination IP	Destination port	Action	Service
1	TCP	Any	Any	Any	17	Deny	QOTD
2	UDP	Any	Any	Any	17	Deny	QOTD
3	TCP	Any	Any	Any	111	Deny	Portmapper
4	UDP	Any	Any	Any	111	Deny	Portmapper
5	TCP	Any	Any	Any	513	Deny	Remote Login
6	TCP	Any	Any	Any	514	Deny	Syslog
7	UDP	Any	Any	Any	514	Deny	Syslog
8	TCP	Any	Any	Any	635	Deny	mountd (NFS service)

Table 9-6 Filtering UNIX services and ports

© Cengage Learning 2014

Restrict Subnets, Ports, and Protocols, Part 4

- Filtering by service
  - Firewalls can filter by the name of a service
    - You do not have to specify a port number
    - Instead of filtering port 23, specify the Telnet service
  - Packets can be filtered based on ID field in the IP header
  - Firewalls can also filter by the six TCP control flags
  - Firewalls can also filter by the IP options
    - Security
    - Loose resource and record routing
    - Strict source and record routing
    - Internet timestamp

© Cengage Learning 2014

Restrict Subnets, Ports, and Protocols, Part 5

- Filtering by service (continued)
  - IPv6 contains many messages and responses
    - Such as Neighbor Discovery, Router Discovery, and Stateless Autoconfiguration
  - This information should be prevented from leaving the internal network but must pass through internal firewalls

© Cengage Learning 2014

Restrict Subnets, Ports, and Protocols, Part 6

- Filtering by service (continued)
  - Rules should follow a few general practices
    - Firewall with a “Deny All” security policy should begin by allowing services selectively as needed
    - Should keep everyone but administrator from connecting to the firewall
    - Should block direct access from the Internet to any computer behind the firewall
    - Should permit access to public servers in the DMZ and enable users to access the Internet

© Cengage Learning 2014

A Typical Packet-Filtering Rule Base

Rule	Source IP	Source port	Destination IP	Destination port	Action	What it does
1	192.168.120.1	Any	Any	Any	Deny	Prevents the firewall from making any connections
2	Any	Any	192.168.120.1	Any	Deny	Prevents anyone from connecting to the firewall
3	192.168.120.0	Any	Any	Any	Allow	Allows internal users to access external computers
4	192.168.120.0	Any	192.168.120.4	53	Allow	Enables internal users to connect to the DNS server on port 53
5	Any	Any	192.168.120.2	25	Allow	Allows external and internal users to access the e-mail server via SMTP port 25
6	192.168.120.0	Any	192.168.120.2	110	Allow	Enables internal users to connect to the e-mail server using POP3 port 110
7	Any	Any	192.168.120.3	80	Allow	Enables both external and internal users to connect to the Web server on HTTP port 80
8	Any	Any	Any	Any	Deny	Blocks all traffic not covered by previous rules

Table 9-7 A typical packet-filtering rule base

Control Internet Services, Part 1

- Web Services Rules
  - Employees need ability to use Internet and exchange e-mails

Rule	Protocol	Transport protocol	Source IP	Source port	Destination IP	Destination port	Action
1	HTTP outbound	TCP	207.177.178.0/24	Any	Any	80	Allow
2	S-HTTP outbound	TCP	208.177.178.0/24	Any	Any	443	Allow

Table 9-8 Outbound Web access

© Cengage Learning 2014

Control Internet Services, Part 2

- DNS Resolution
  - Resolves fully qualified domain names (FQDNs) to their corresponding IP addresses
  - DNS uses UDP port 53 for name resolution
  - DNS uses TCP port 53 for zone transfers

Rule	Protocol	Transport protocol	Source IP	Source port	Destination IP	Destination port	Action
3	DNS outbound	TCP	208.177.178.31	Any	Any	53	Allow
4	DNS outbound	UDP	208.177.178.31	Any	Any	53	Allow
5	DNS inbound	TCP	Any	Any	208.177.178.31	53	Allow
6	DNS inbound	UDP	Any	Any	208.177.178.31	53	Allow

Table 9-9 DNS resolution rules

© Cengage Learning 2014

Control Internet Services, Part 3

- E-mail Configuration
  - Setting up firewall rules that permit filtering e-mail is not simple
  - Variety of e-mail protocol that can be used:
    - POP3 and IMAP4 for inbound mail transport
    - SMTP for outbound mail transport
    - Lightweight Directory Access Protocol (LDAP) for looking up email addresses
    - HTTP for Web-based email service
  - Secure Sockets Layer (SSL) encryption should be used for additional security

© Cengage Learning 2014

E-mail Rules

Rule	Protocol	Transport protocol	Source IP	Source port	Destination IP	Destination port	Action
7	POP3 outbound	TCP	208.177.178.0/24	Any	Any	110	Allow
8	POP3/S outbound	TCP	208.177.178.0/24	Any	Any	995	Allow
9	POP inbound	TCP	Any	Any	208.177.178.0/24	110	Allow
10	POP3/S inbound	TCP	Any	Any	208.177.178.0/24	995	Allow
11	SMTP outbound	TCP	208.177.178.29	Any	Any	25	Allow
12	SMTP/S outbound	TCP	208.177.178.29	Any	Any	465	Allow
13	SMTP inbound	TCP	Any	Any	208.177.178.29	25	Allow
14	SMTP/S inbound	TCP	Any	Any	208.177.178.29	465	Allow

Table 9-10 E-mail rules

Control Internet Services, Part 4

- FTP Transactions
  - Types of FTP transactions
    - Active FTP
      - If supported by some clients in your network, you cannot specify a port because the client can establish a connection with the FTP server at any port above 1023
      - Instead, specify the IP address of your FTP server
    - Passive FTP

© Cengage Learning 2014

FTP Rules

Rule	Protocol	Transport protocol	Source IP	Source port	Destination IP	Destination port	Action
15	FTP control inbound	TCP	Any	Any	208.177.178.0/25	21	Allow
16	FTP data inbound	TCP	208.177.178.0/25	20	Any	Any	Allow
17	FTP PASV (passive)	TCP	Any	Any	208.177.178.0/25	Any	Allow
18	FTP control outbound	TCP	208.177.178.0/25	Any	Any	21	Allow
19	FTP data outbound	TCP	Any	20	208.177.178.25	Any	Allow

Table 9-11 FTP rules

Control Internet Services, Part 5

- ICMP Message Types
  - ICMPv4 and ICMPv6 function as housekeeping protocols for TCP/IP
    - Helps networks cope with communication problems
  - ICMPv4 packets have no authentication method
    - Attackers can use ICMP packets to attempt man-in-the-middle attacks
  - Firewall/packet filter must be able to determine whether an ICMP packet should be allowed to pass, based on message type

© Cengage Learning 2014

Filtering ICMP Message Types

Rule	INT	EXT	Protocol	ICMP type	Source IP	Source port	Destination IP	Destination port	Action
20			ICMP	Source Quench	Any	Any	Any	Any	Allow
21	X		ICMP	Echo Request	Any	Any	Any	Any	Deny
22		X	ICMP	Echo Reply	Any	Any	Any	Any	Deny
23	X		ICMP	Destination Unreachable	Any	Any	Any	Any	Allow
24		X	ICMP	Redirect	Any	Any	Any	Any	Deny
25		X	ICMP	Destination Unreachable	Any	Any	Any	Any	Deny
26			ICMP		Any	Any	Any	Any	Deny

Table 9-12 Filtering ICMP message types

Control Internet Services, Part 6

- ICMP Message Types (continued)
  - ICMPv6 message types to pass through firewalls but never outside the organization:
    - Destination Unreachable (Type 1) – All codes
    - Packet Too Big (Type 2)
    - Time Exceeded (Type 3) – Code 0 only
    - Parameter Problem (Type 4) – Codes 1 and 2 only
    - Echo Request (Type 128)
    - Echo Response (Type 129)
    - Time Exceeded (Type 3) – Code 1
    - Parameter Problem (Type 4) – Code 0

© Cengage Learning 2014

Summary, Part 1

- Firewall is hardware or software that blocks unauthorized network access
- Firewalls are not a standalone solution
  - Combine them with antivirus software, IDPSs, access control, and auditing
- Software firewalls come as freeware, shareware, and commercial enterprise applications
- Hardware firewall appliances are more expensive, but can handle more traffic
- Stateless firewalls filter traffic based on protocol or IP address but are less secure than stateful firewalls

© Cengage Learning 2014

Summary, Part 2

- Stateful firewalls maintain state tables, which are records of connections that are considered trusted
- Firewalls are effective only if they are configured correctly to block undesirable traffic and allow necessary traffic
- Firewall rule base should be based on the organization's security policy, provide rules for how applications can access the Internet, and be as simple and short as possible

© Cengage Learning 2014